Saturday, February 27, 2021 8:16 PM

Domain 7: Security Operations

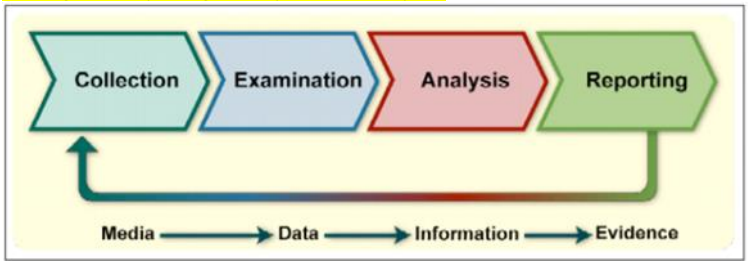
- **Understand and support investigations**
  - Security Operations
    - Execute the daily tasks required to keep security services operating reliably and efficiently.
  - Operational Security
    - Protect and control information processing assets in centralized and distributed environments.
  - **The Incident Scene**
    - Incident response is corrective control
    - The Incident scene is the environment where potential evidence may exist
    - The principle of criminalistics apply in both case:
      - Identity the scene
      - Protect the environment
      - Identify evidence and a potential source of evidence
      - Collect evidence
      - Minimize the degree of contamination
    - Live Evidence
      - It's a challenge to collect the Live Evidence.
      - Data that is dynamic and exists in processes that disappear in a relatively short time frame once the system is powered down, stored in RAM, exists in the running processes. Data might be lost when you power off the system.
    - **Locard's Exchange Principle** during incident/investigations.
      - When a crime is committed, the perpetrators leave something behind and take something with them.
    - General Guidelines
      - All general Forensic and procedural principles must be applied
      - Seizing digital evidence must not alter the evidence
      - Any person accessing original digital evidence must be trained.
      - All activity relating to the seizure, access, storage, or transfer of digital evidence must be fully documented, preserved and available for review.
      - While an individual is in possession of digital evidence, he or she is responsible for all actions
      - Any agency responsible for seizing, accessing, storing, or transferring digital evidence is responsible for compliance with these principles.
  - **Electronic Discovery Reference Model (EDRM) EXAM IMP**



    - **EDRM Stages**
      - Information Governance – Getting your electronic house to mitigate risk & expenses should e-discovery become an issue, from the initial creation of ESI (electronically stored information) through its final disposition.
      - Identification – Locating potential sources of ESI & determining its scope, breadth & depth.
      - Preservation – Ensuring that ESI is protected against inappropriate alteration or destruction.
      - Collection – Gathering ESI for further use in the e-discovery process (processing, review, etc.).
      - Processing – Reducing the volume of ESI and converting it, if necessary, to forms more suitable for review & analysis.
      - Review – Evaluating ESI for relevance & privilege.
      - Analysis – Evaluating ESI for content & context, including key patterns, topics, people & discussion.
      - Production – Delivering ESI to others in appropriate forms & using appropriate delivery mechanisms.
      - Presentation – Displaying ESI before audiences (at depositions, hearings, trials, etc.), especially in native & near-native forms, to elicit further information, validate existing facts or positions, or persuade an audience.
- **Evidence collection and handling**
  - All Material associated with an incident could be pertinent to an investigation and used as evidence:
    - Data that may have been compromised.
    - System (hardware, Software, and media) that may have been compromised.
    - Data about the incident (all monitoring data from assets reviewing the data/system that may have been compromised)
    - Information from people with knowledge of the incident.
    - Information about the incident scene.

- Some common practices for handling evidence that the security professional should be aware of:
  - Chain of custody
  - Copies of all data/system states
  - Analyze copies instead of originals where possible
  - Appointment of evidence custodian.
- Chain of Custody
  - Part of evidence collection handling (What, Where, When, Why and How)
  - Tracks evidence handling
  - A formal, well-documented process must be followed -no exceptions
- Chain of Evidence
  - Process by which you collected all the evidence,
  - Ex: obtain evidence from the firewall, host1, host2,..etc similar to a chain
- While Presenting Evidence, the security practitioner should adhere to these tenants
  - Admissibility
    - Only evidence that is acceptable to the court may be presented
  - Accuracy
    - Evidence should be true and clear
  - Comprehensibility
    - Keeping contrary evidence out of consideration may be a crime in some case
  - Objectivity
    - The evidence should stand for itself on a factual basis.

- **Digital forensics tools, tactics, and procedures**
  - Document everything
  - Avoid unrecorded/unintended modification
  - Collection is a sensitive process
  - No amateur involvement
  - Digital Forensics data must BE Authentic, Accurate, Complete, Convincing, Admissible
  - Five rules of evidence:
    - Be authentic; evidence tied back to the scene
    - Be accurate; maintain authenticity and veracity
    - Be complete; all evidence collected, for & against the view
    - Be convincing; clear & easy to understand for jury
    - Be admissible; be able to be used in court
  - Data Forensic Process
    - Data Collection - Collection data from a server
    - Data Examination - Exam what is an imp and what not from the data
    - Data Analysis - Conduct analysis on the sorted data to understand the relation with the incident.
    - Investigation Reporting - than present the report



Volatile Order (should be collected, from first to last)
1. Network connections
2. Login sessions
3. Contents of memory
4. Running processes .
5. Open files
6. Network configuration
7. Operating system time.

  - Some general digital forensics principles the candidate should be aware of:
    - **Document everything**
      - All actions were taken by the forensic analyst (and, indeed, by anyone who has/had access to the material is taken as evidence) should be thoroughly recorded and annotated.
  - The documentation should be so thorough that anyone else starting with the same original material could follow the documented process and end up with the same material resulting from the analysis.
  - Documentation should include all steps of the chain of custody, including evidence collection/capture, analysis, and storage.
- **Avoid unrecorded/unintended modification**
  - When capturing and analyzing systems/media and related data, forensic practitioners should act to preserve the original version/state of the material.
- **Collection is a sensitive process**
  - When considering a forensic analysis of evidence, this discussion needs to be combined with the “Mitigation” topic of the previous module in this domain: there is a tradeoff between the speed of response to minimize damage/risk and the potential for capturing/collecting significant evidence

- **Not an amateur endeavor**
  - Most organizations do not have trained forensic practitioners on staff because that is a very specific discipline, requiring extensive training and experience, for an activity that is not at all common in most business endeavors.

- Investigative techniques
  - Interviewing
    - Investigators must keep in mind concerns, such as:
      - Due process
      - The rights of the individual being questioned
      - Considerations unique to the organization or jurisdiction
  - Media Analysis
    - Recovery of information or Evidence from information media
    - The media may have been damaged overwritten, degaussed, or reused
    - Slack space and shadow volume analysis
    - Disk Imaging and Timeline analysis (modify, access, create times)
  - Network Analysis
    - Analysis examination of data from network logs and activity for potential evidence
    - The critical phase of the process is proper evidence management and handling
  - Software Analysis
    - Encompasses investigative activities:
      - Malware analysis
      - Intellectual property disputes
      - Copyright infringements
    - Goal
      - Author identification
        - Attempts to determine who is the creator or author of the software/program in question
        - Each author has a unique style that distinguishes between potential suspects
      - Content analysis
        - The systematic analysis of the code's purpose
        - Used in cases related to intellectual property disputes
        - Develops a high-level view of the impact
      - Payload and context analysis
  - Hardware / Embedded Device Analysis
    - The standard hardware and firmware in a laptop or a desktop computer's motherboard
    - Special tools and techniques are required to image embedded devices
    - Many embedded devices cannot be read or copied without altering the relevant information
    - Its difficult to find vulnerabilities on hardware
- Reporting and documentation
  - Reports based on and supported by evidence should contain enough information to relate the entirety of the incident/situation without the need for subjective or convoluted interpretation
  - If an incident response team suspects that an incident has occurred they should start recording information about the incident.
  - Any and all information specific to the incident in question should be captured and time-stamped
  - All documents should be dated and signed by the investigators.

- **Understand requirements for Investigation Types**
  - Jurisdiction
    - Investigation always driven by Jurisdiction varies by country by country. Responsibility is often ambiguous.
  - Types of Investigations
    - Operational (limited to the organization boundary)
    - Criminal (applied science that involves the study of facts that are then used to inform criminal trials)
    - Civil (resolves a dispute between two parties)
    - eDiscovery (Collect documents, emails, processing can be used for other types) subpart of Digital forensics.
      - Electronic Discovery Recovery Model
        - Information Governance -The Electronic Discovery Reference Model (EDRM) is a framework that outlines standards for the recovery and discovery and of digital data. The EDRM is designed to serve as guidance for gathering and assimilating electronic data during the legal process, including criminal evidence discovery.
  - Different types of investigations, depending on the nature of various incidents
    - Administrator
      - An administrative investigation is conducted when the entirety of the process will be contained within the organization; **it exists solely as an internal function**.
      - When conducting administrative investigations, **the organization can follow its policies and procedures** as long as they comply with applicable law(s).
    - Criminal
      - When a crime is committed, the organization is usually required to notify the applicable law enforcement entity and allow that entity to conduct the investigation.
      - When law enforcement conducts the investigation, the organization may or may not be involved in the process; this is the option of the law enforcement body.
      - Once a criminal investigation has begun, the organization’s policies and procedures are superseded, and the organization’s investigative efforts must comply and not interfere with the law enforcement investigation.

- Civil
  - If an organization decides to become involved in a civil suit, it must be understood that the organization will be bearing the financial burden: attorneys' and court fees, and so forth.
  - Another aspect to be aware of is the threshold of proof required: **in civil cases, the burden of proof is usually much lower than in criminal cases** A civil investigation is typically triggered when a lawsuit is imminent or ongoing. It is similar to a criminal investigation, except that instead of working with an LEA you will probably be working with attorneys from both sides (the plaintiff is the party suing and the defendant is the one being sued). Another key difference in civil (versus criminal) investigations is that the standard of proof is much lower; instead of proving beyond a reasonable doubt, the plaintiff just has to show that the preponderance of the evidence supports the allegation.

- Regulatory
  - In Some European countries, there are several government departments and independent agencies that have the power to investigate and prosecute people or businesses for breaking the law or breaching regulatory
  - The Department or lead agencies have the power to investigate tax evasion, or they have the power to investigate breaches of environmental law; can investigate breaches of codes of conduct by businesses or professionals that provide financial services.
  - Regulators may conduct their investigations, require the target organization to acquire and present information to the regulator, or engage a third party to perform the investigation
- Industry Standard
  - There are many industry standards for investigations of all sorts, including IT security and data investigations; applicable standards for a given organization depend on a host of variables, such as geographic region/ jurisdiction, the nature of the data in question, the business of the organization, and so forth.

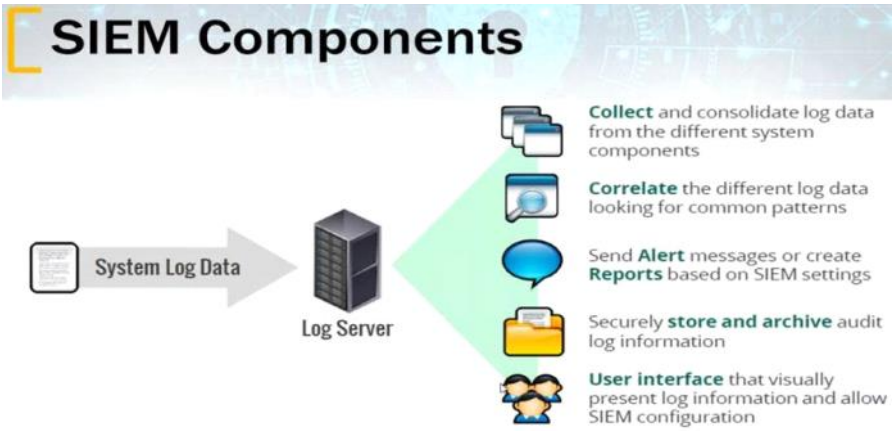
Always treat an investigation, regardless of type, as if it would ultimately end up in a courtroom.

- **Conduct Logging and Monitoring Activities**
  - Intrusion detection and prevention (IDS & IPS)
    - One major area of IT security concerns the confidentiality aspect of the CIA Triad.
    - IDS - Intrusion Detection Systems - > Detective (Outline mode)
      - A Technology that alerts organizations to adverse or unwanted activity. IDS is considered as network monitoring and audit technology.
    - IPS - Intrusion Prevention systems -> Preventive control (Inline model)
      - Monitors activity like an IDS, but automatically takes preventive action if an unacceptable activity is detected. IPS consider as access control and policy enforcement.
    - IDS/IPS solutions can be deployed at various physical and logical locations in the IT environment. This includes the following:
      - **Perimeter placement:** The IDS/IPS can be placed as or with the gateway for traffic entering and leaving the environment, within the DMZ, or on the boundary of the DMZ (external facing); in this respect, it is similar to firewall placement.
      - **Host-based:** IDS/IPS agents can be installed on various endpoint systems to detect maliciously or suspect traffic between hosts
      - **Network-based:** IDS/IPS elements can be placed at various points of the network as a means to monitor internal traffic and recognize malicious or suspect activity internally.
    - IDS/IPS can detect malicious activity in several ways:
      - **Deviation:** Deviations from this baseline of expected behavior are deemed, suspect.
      - **Signature:** The IDS/IPS can recognize known attack patterns in traffic and activity.
      - **Heuristic:** Machine-learning algorithms
    - IDS/IPS solutions, like all tools that need to "learn" the typical activity/behavior in your environment, will not work perfectly right out of the box; there will be a period during which the tool will have to become familiar with the expected norms.
    - While intrusion detection and prevention are typically intended to obviate attacks on the confidentiality aspect of the CIA Triad.
    - Tuning the IDS
      - A Critical requirement to establish IDS capabilities is to tune into the unique traffic patterns of the organization. It's important to tune both IDS and DLP according to organizational requirements due to False positives.
  - **Security Information and Event Management (SIEM) (EXAM IMP)**
    - The current trend in security management involves the use of tools that collect information about the IT environment from many disparate sources to better examine the overall security of the organization and streamline security efforts. These tools are generally known as SIEM solutions.
    - The general idea of a SIEM solution is to gather log data from various sources across the enterprise to better understand potential security concerns and apportion resources accordingly.
    - Some common functions of SIEM solutions include the following:
      - Aggregation
        The SIEM tool gathers information from across the environment. This offers a centralized repository of security data and allows analysts to have a single interface with which to perform their duties.
    - The SIEM Might gather log data from :
    - Firewalls, IDP/IPS System, IT performance monitoring tools, Network Devices, Host/Endpoint, Anti-Malware Solutions.
      - Normalization
      - SIEM tools can often collect different types of information from different types of sources and present the data in a meaningful, standardized way, such that the analysis task is simplified; analysts can use the SIEM tool instead of repeating various log review actions on multiple systems.
    - Correlation
      - The SIEM may be able to mathematically assign weight and probability to various activities throughout the enterprise as a means of automatically calculating a probability that a given stream of log information is an actual attack, whether the attack affects more than host/location/network and the likelihood and significance of input.
  - Secure Storage
    - SIEM tools often offer the ability to archive the material they contain in a secure manner
  - Analysis
    - Some SIEM solutions perform automated analyses, using scripts and heuristics.
  - Reporting

    - SIEM solutions often offer reporting tools for distilling current and historical depictions of the activity in your environment.
  - Security Information Manager (SIM) - A tool to collect audit logs into a central location or repository
  - Security Event Manager (SEM) - A tool used to correlated, inspect, or analyze audit logs

    SIEM = SIM + SEM

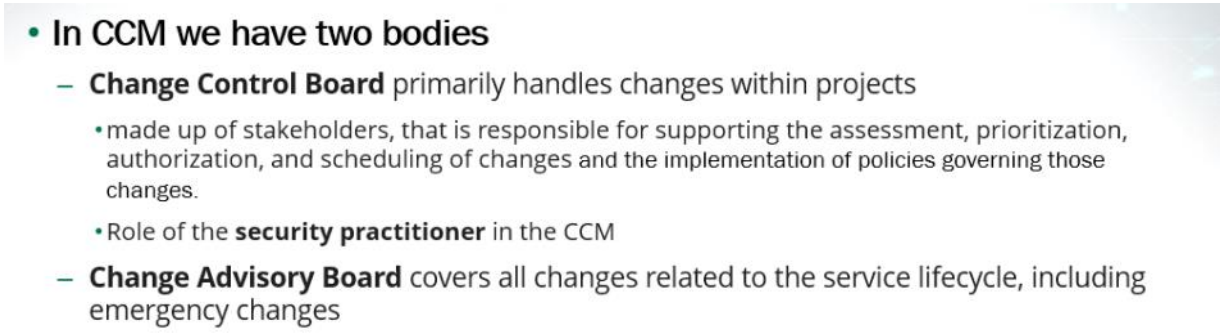
- SLEM Components



- Continuous Monitoring
  - Log Management System
    - Log management system also collects logs and provides reports.
    - Their focus is on historical analysis rather than real-time analysis.
    - May be combined with SIEM solutions to provide historical and real-time analysis.
    - A critical requirement of Log management system is **Time Stamp and correlation (NTP Protocol is used)**
  - Egress Monitoring
    - Egress monitoring is used to regulate data leaving the organization's IT environment.
    - Filtering and restricting the flow of outbound information from one network to another helps ensure unauthorized or malicious traffic never leaves the internal network.
    - Primary objective is should not to leave unauthorized traffic outside. Firewall can verify the packets and traffic from inside to outside. ingress monitoring is traffic from outside to inside.
    - DLP (Data leak protection or Data loss protection)
      - A Suite of technologies to reduce the loss of sensitive information to an expectable level
      - DLP tools function by comparing data leaving the control of the organization against a rule set to determine whether that action is allowed.
      - The DLP rule set can be defined by the following:
        - **Signature:** Particular types of data might conform to certain strings that are readily identifiable
        - **Pattern matching:** The DLP might be conditioned to look for two-word strings where each word starts with one uppercase character and the rest are lowercase; in this way, the DLP might restrict the export of individual names.
        - **Labeling:** Sensitive assets within the environment might be tagged with specific labels that will be recognized by the DLP tool. **Fastest**
      - **Valuable for false-positive Pattern Matching and Labeling**
      - For DLP solutions to function properly, they usually need to be deployed in conjunction with and as part of an overall data protection effort within the organization.
      - Deployment is often construed as having three facets:
        - **Data at rest:** Placement of DLP agents in data storage locations (both physical and logical), such as databases and archives.
        - **Data in motion:** DLP software that inspects outbound communications traffic. (Network)
        - **Data in use:** DLP agents installed on endpoint devices.
      - **Which state of data we use DLP More effectivity - Data in Use / Data at share, But more in Data in Use**
      - **DLP with DRM provides effective protection /security for data exfiltration.**
      - DRM is compensating control with DLP, **Digital (Data) rights management (DRM) is a systematic approach to copyright protection for digital media**.
      - The purpose of DRM is to prevent unauthorized redistribution of digital media and restrict the ways consumers can copy content they've purchased.
  - Ingress Monitoring
    - Ingress monitoring refers to surveillance and assessment of all inbound communications traffic and access attempts.
    - Devices and tools that offer to log and alerting opportunities for ingress monitoring include the following:
      - Firewalls ,Gateways ,Remote authentication servers ,IDS/IPS tools ,SIEM solutions ,Anti-malware solutions
      - As with all security tools, solutions used for ingress monitoring must be maintained, patched, and updated as necessary for signature libraries and configuration changes. Also, the overhead cost in terms of both maintenance of these tools and impact on productivity must be considered.

- **Securely provisioning resources**
  - Asset Inventory/Asset Management
    - The organization must determine what assets the organization has to properly protect those assets. This effort is known as **asset management**, and the primary tool is the **asset inventory**
    - Asset management entails a formalized process for selecting, acquiring/developing, maintaining, and disposing of all assets within the organization. If designed properly, the asset management process should also include security elements in each step.

- The asset inventory is a comprehensive, detailed log of all assets within the organization.
- The asset inventory is often created during and in conjunction with the business impact analysis (BIA) effort.
- When possible, the asset inventory should reflect the following:
  - Asset owner
  - Asset location (logical location, physical location, and its location in the organizational hierarchy, as applicable)
  - Asset value (either market value or acquisition price/cost; this is usually determined by the asset owner at the time of acquisition/ development)
  - Annual cost of maintenance
  - Projected duration of the asset lifespan
  - Asset security classification, if relevant
  - Any other pertinent information about the asset; could include dependencies on other assets, the office/entity responsible for maintaining the asset, etc.
- Asset inventory can and should include all these characteristics and values, a database is often used to maintain the asset inventory.
- The asset inventory also serves other security efforts, such as mapping controls to assets, providing audit artifacts, and serving as proper documentation for business continuity and BCDR plans and processes.

- **Configuration Management**
  - Configuration management is a formal, methodical, comprehensive process for establishing a baseline of the IT environment.
  - A discipline for evaluation, coordinating, approving, or disapproving, and implementing changes to artifacts used to construct and maintain software systems. Change Management works with Configuration Management together.
  - Organizations apply configuration management (CM) for establishing a baseline and for tracking, controlling, and managing many aspects of business development and operations.
  - Organizational stockholders must review and accept changes before they are introduced.
  - All system changes are documented and approved before the change occurs.
  - The system baseline is updated based on CM approved changes
- **Configuration Control Board**
  - A group of qualified people with responsibility for the process of controlling and approving changes throughout the development and operational lifecycle of the products and system.
  - The process involves a Change/Configuration Management Board (CMB); a group of stakeholders who participate in regular meetings to review requests to modify the environment or make an exception to the baseline
  - Modification requests normally come from departments, managers, and users within the organization, and include desired changes such as adding components/systems to the environment, creating exceptions to security control mechanisms, granting access to a particular system/data set, and so forth
  - CCB Focus: system versions, CM Plan with document all details of managing Configuration management.
  - Change Advisory board - approve/reject the changes.
  - The first step to manage the configuration - Baseline is a starting point, Maintain baseline to make the configuration management easier.
  - 

- **Understand and apply foundational security operations concepts**
  - Need-to-Know/Least Privilege
    - **Need-To-Know:** Primarily associated with organizations that assign clearance levels to all users and classification levels to all assets; restricts users with the same clearance level from sharing information unless they are working on the same effort. Entails compartmentalization.
      - Implementing need-to-know methods can protect information from unauthorized disclosure or espionage, or can be used to enhance the investigation of a suspected information compromise.

  - **Least Privilege:** No employee should have access to or authority over any system or data unless it is necessary for the employee to perform their job function.
    - For example, ordinary users should not be delegated elevated privileges on a system unless they are promoted to a system administrator. Likewise, individuals should not have unlimited access to organizational information. Users should be restricted from accessing sensitive information unless it is necessary in the performance of the
      assigned duties
      Need-to-know is generally applied to people, while least privilege is generally applied to processes.

  - **Separation of Duties**
    - Separation of duties necessarily degrades the efficiency of operations but with the benefit of making the process more secure.
  - **Job Rotation**
    - The organization can implement the practice of job rotation, where all employees change roles and tasks regularly. This improves the overall security of

the organization in several ways
    - An employee engaged in wrongdoing in a specific position may be found out when the replacement takes over that position after rotation.
    - The organization will have a staff that has no single point of failure; every person on a team will know how to perform all the functions of that team
- **Information Lifecycle**
    - The data lifecycle stages can be described as the following:
        - **Create** The moment the data is created or acquired by the organization.
        - **Store:** Near-time storage for further utilization; this takes place almost simultaneously with creation of the data.
        - **Use:** Any processing of the data by the organization.
        - **Share** Dissemination of the data typically considered outside the organization (internal "sharing" would most often be considered "Use"); this can include the sale of the data, publication, and so forth.
        - **Archive:** The data is moved from the operational environment to long-term storage; it is still available for irregular purposes (disaster recovery, for instance, or possibly to replace operational data that was accidentally deleted) but is no longer used regularly.
        - **Destroy:** Data is permanently removed from the organization with no way to recover it.
- **Trusted Paths & Fail Secure Mechanisms**
    - Trusted Paths
        - Provides trustee path between the user and the server.
        - A trusted path or trusted channel is a mechanism that provides confidence that the user is communicating with what the user intended to communicate with, ensuring that attackers can't intercept or modify whatever information is being communicated.
- **Fail-safe mechanisms**
    - Failing with minimum amount of harm.
    - A fail-safe in engineering is a design feature or practice that in the event of a specific type of failure, inherently responds in a way that will cause no or minimal harm to other equipment, the environment, or to people.
- **Fail-secure**
    - Focus on blocking access, no traffic flows
    - Fail Secure Locks. So in the end fail secure means that if the power is interrupted or fails, the door stays locked. That's why it's called "secure": Its default state is locked or secured. So a fail-secure lock locks the door when power is removed.
- **Threat Intelligence**



    - Benefits of information sharing include:
        - Shared Situational Awareness
        - Improved Security Posture
        - Knowledge Maturation
        - Greater Defensive Agility
    - Challenge to information gathering
        - Establishing Trust
        - Achieving Interoperability and Automation
        - Safeguarding Sensitive Information
        - Protecting Classified Information

User and entity behavior analytics (UEBA)

- **User and entity behavior analytics is bringing profiling and anomaly detection based on machine learning to security, to detect malicious and abusive activity that otherwise goes unnoticed.**
  - Profile and baseline the activity of users
  - Form peer groups based upon common user activities, using directory groupings and human resources
  - Correlate user and other entity activities and behaviors
  - Detect anomalies using statistical models, machine learning and/or rules that compare activity to profiles.
- **An effective UEBA the solution has at least the following properties:**
  - Effective data collection and data representation layer
  - Correlation of entities identifiers to users and user accounts to users
  - Abnormal behavior detection
  - Specific threat detection



68

User and entity behavior analytics (UEBA)

The effectiveness of an UEBA greatly depends on these core components:

- 1. Focused threat scenarios and use cases
- 2. Availability of relevant data sources and variables
- 3. Appropriate analytics algorithms

Three Pillar of UEBA

- Use Cases
  - behavior of users and other entities in the corporate
- DATA Sources
  - Ingest data from a general data repository such as a data lake or data warehouse
- Analytics
  - detect anomalies using a variety of analytics approaches–statistical models, machine learning, rules, threat signatures and more

69

- **Privileged account management**
  - Privileged accounts are those with permissions beyond that of normal users, such as managers and administrators. Because those permissions lend the privileged user more capability to cause potential harm to the organization, privileged accounts require additional protections.
  - Typical measures used for attenuating elevated risks from privileged accounts include the following:
    - More extensive and detailed logging than regular user accounts
      - The record of privileged actions is vitally important, as both a deterrent and administrative control.
    - More advanced access control than regular user accounts.
      - Password complexity requirements should be higher for privileged accounts than regular accounts and refresh rates should be more frequent
    - Temporary access
      - Privileged accounts should necessarily be limited in duration; privileged users should only have access to systems/data for which they have clear need-to-know and only for the duration of the project/task for which that access is necessary.
  - Deeper trust verification than regular users
  - Privileged account holders should be subject to more detailed background checks, stricter nondisclosure agreements, and acceptable use policies and be willing to be subject to financial investigation.
  - Greater audit of privileged accounts.
  - Privileged account activity should be monitored and audited at a greater rate and extent than regular usage
- **Service-Level Agreements (SLAs)**
  - The SLA codifies specific performance elements with discrete, objective metrics required for fulfillment so that the customer knows what to expect, and the provider knows what to deliver.

- A Service-level agreement (SLA) is simply a document describing the level of service expected by a customer from a supplier.
- An SLA Pulls together information on all of the contracted services and their agreed-upon expected reliability into a single document
- **SLA needs to review Annually, OLA needs to be review daily in meetings.**
- **Most important to consider is the Right to Audit.**
- **SLA also act as third party governance between two organization.**
- SLA should include components in two areas:
  - Services - Service elements include specifics of services provided
  - Management - Management elements should include definitions of measurement standards and methods, reporting process, contents and frequency, a dispute resolution process.
- What kind of metrics should be monitored
  - Service availability
  - Defect Rates
  - Technical Quality
  - Security
- When should we review our SLA's
  - As a Business Change
  - Technical Requirement has changed
  - Workloads have changed
  - Metrics Measurement tools and processes have been improved

- **Third-Party Service**
  - Whenever an organization contracts for services from an external provider, the following elements should be considered.
    - Strong contract language protecting both parties.
    - Mutual review of security governance to ensure that there is a common understanding of goals and approaches.
    - Nondisclosure agreements (NDAs), ensuring that data belonging to the client organization is not exploited by the contractor.
    - Contractor should provide evidence of errors/commissions insurance and proper bonding when entrusted with the organization assets.
    - Auditing/review of a contractor on a regular basis
    - Full approval from the regulator in affected industries before outsourcing is implemented.
  - **Third-party provided security services (Exam Point)**
    - When contracting with third-party services of any kind, it is important to perform due diligence in the form of research about the provider's ability to perform the required tasks and maintain the necessary level of customer satisfaction and protection of assets.
    - This often entails (but is not limited to) the following measures:
      - Review of governance:
        - The client should review the provider's approach to service provision, including security policy and procedures.
      - Service-level agreements (SLAs):
        - The client and provider must agree, explicitly, what constitutes full and accurate satisfaction of the terms of service.
      - Nondisclosure agreements (NDAs):
        - Similar to the agreement between employer and employee the provider must agree to protect and limit dissemination of any of the customer's data that the provider may access during the provision of the service. This also includes the provider agreeing not to take any action beneficial to the provider based on the customer's information
      - Insurance/bonding:
        - Professional service providers are necessarily in a position to cause a significant negative impact on the customer and should obviate that risk to build trust in the relationship. One technique for accomplishing this is to provide financial assurance that the customer will receive restitution for any damages resulting from the provider's negligence/failures. Common methods include a form of risk transference, such as a surety bond or errors and omissions insurance policies.
      - Audit/testing:
        - The provider should allow the customer to perform surveys s/reviews of the provider's operation and the service itself; these can take the form of on-site audits, performance monitoring, penetration testing, etc.
      - Strong contract language:
        - All terms of the managed service must be enforceable and legitimate for all jurisdictions and applicable laws where the service will be rendered. This should involve an exhaustive review by legal counsel for both parties.
      - Regulatory approval:
        - As in all matters involving compliance requirements, any regulators that oversee the organization need to be informed and grant acceptance of any managed service that might affect compliance.

- **Apply resource protection techniques**
  - Media Management
    - Media is any object that contains data; this can include hardware embedded in a networked environment (hard drives and drive arrays), items designed for data portability (flash drives and disks), and even non-electronic substrates (paper or microfilm/fiche, often called "hardcopy"). Like the data itself, media needs to be protected.
  - Media protection can use the following techniques/mechanisms
    - Technical/logical:
      - Media can be encrypted so that the resident data cannot easily be accessed even if someone with malicious intent has physical possession of the media.
      - Strong access controls can be implemented on the media itself or the software within the media, making it resistant to unauthorized access.
      - Tracking mechanisms can be embedded in the media such that, in the event, the media is stolen and reconnected to another system and then the internet, the media will notify the rightful owner.
      - Digital watermarks/signatures can be embedded in the content of the media, so any unauthorized replication/use can later be determined and used as evidence in legal claims.
    - Physical:

        - Physical access to the media itself can be severely restricted through the use of common physical protective measures (walls, door locks, guards, cameras, alarms, etc.) in a program that utilizes defense-in-depth design, multifactor authentication, and/or two-person integrity.
        - The organization can implement severe media control procedures, including searching personnel as they enter and leave the workplace, metal detectors, etc.
    - Administrative:
        - In conjunction with one or both of the other types of controls (physical, technical), policy and procedures can be crafted to restrict access to and control of media.
        - Purchase/acquisition and deployment of media can be rigidly controlled by a defined, formalized process.
    - Hardware and Software Asset Management
        - Software asset management involves a similar but slightly different approach than media or hardware; media and hardware involve tangible objects as well as data, while the software is strictly electronic information applied to the environment.
- Media Management Protection
    - Encryption
    - Encryption during transportation
    - Removal Media
    - Cloud Storage
    - Virtual Storage

- **Conduct incident management**
    - Security Incident
        - A security incident is an event or action that endangers the confidentiality, integrity, or availability of information or information systems.
        - A data breach is when data is exfiltrated or extracted or there is a loss of control. A data breach may trigger reporting and notification requirements
    - Incident Response
        - Most simple form of Incident response is **detecting a problem, determining its cause, minimizing the damage, resolving the problem, and documenting each step**.
        - The primary objective of incident management is to limit the incident, to limit the impact to the organization objectives, **Incident Response is reactive control.(Corrective control)**
        - **Steps involved in handling the security incident are categorized in the following stages**
            - **Identification of the problem, containment of the problem, Eradication of the problem, recovering from the incident, and follow-up analysis.**
        - Common framework to these models include:
            - Creation of response capability
            - Incident handling and response
            - Recovery and feedback

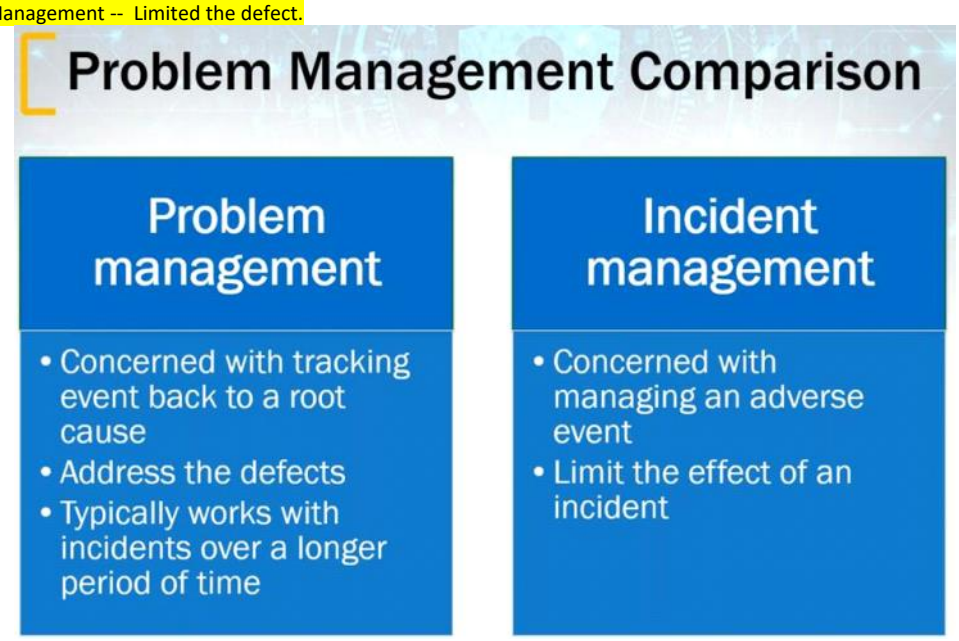
- **Incident Management (DRMR3L) (EXAM IMP)**
    - A standard approach to incident management involves these phases:
        - Detection
        - Response
        - Mitigation
        - Reporting
        - Recovery
        - Remediation
        - Lessons learned
    - Detection
        - The first step in handling an incident is discovering that an incident may have taken place.
        - The step of the process involves finding the possible incident and notifying the proper entitles.
        - There are a variety of methods and mechanisms for detecting possible incidents, including both automated solutions and human involvement. These can include the following:
            - Intrusion detection systems (IDSs)/intrusion prevention systems (IPSs)
            - Anti-malware solutions
            - Log analysis, Firewalls, Vulnerability scan results, Database activity monitors (DAMs)
            - Data leak protection/data loss prevention (DLP) tools
            - Digital rights management (DRM) solutions
        - Perhaps one of the most prolific and useful sources of incident detection is the user community
        - The user reports a problem to the Helpdesk and a Helpdesk administrator then troubleshoots the problem and discovers something that might be a security incident.
    - Response
        - After the possible incident has been discovered and the proper entities notified, the initial response commences. This step involves determining whether the reported activity is truly an incident, is underway, or has occurred.
        - Involve security practitioners trained and knowledgeable in incident identification and management; someone with experience in incident handling needs to review the situation and, if necessary, formally declare an incident and activate the incident response team.
        - The containment strategy is driven by several criteria:
            - Preserve forensic evidence for possible legal action
            - Availability of services provided by affected components
            - Potential damage of leaving for containment strategy to be effective.
            - Resources are required to contain the affected component.
    - Mitigation / Containment
        - Basically a temporary workaround time.
        - Mitigation effort depends on many factors, including the nature and breadth of the incident, the organization's risk appetite and critical business needs,

and any policy or regulatory drivers.
    - This phase includes the immediate action taken upon determining an incident has occurred/is occurring, but it will not be the final effort in addressing the incident
    - The incident should be handled by a team of subject matter experts that have insight into the various aspects of security and IT
    - Determine how the incident happened
    - Take Steps to prevent an immediate re-infection
- Reporting
    - After the initial mitigation/containment action has taken place, the incident needs to be assessed, analyzed and reported to any other relevant stakeholders
    - Stakeholders may include the following:
        - Customers, Vendors, The public, Regulators, Users/employees, Law enforcement
    - Senior management will decide on the appropriate course of action for the rest of the incident management process
    - The senior manager will decide how the organization (and, specifically, the incident management team) should proceed.
    - All Incident management actions should be thoroughly documented.
- Recovery
    - **Ultimate goal: Resuming full normal operations.**
    - The incident management team can proceed to return the environment to normal operations, taking into account any special activity that must be performed to contain/obviate the effects of the incident.
    - In this phase, the team will take part in addressing the incident itself.
    - Returning to original Site
    - **Recovery we have is done within a defined MTD/RTO after reviewing the SLA.**
    - Restoring data to the production environment.
    - Eradiation (Process for removing threats) **Eradication happens in the Recovery stage**
- Remediation
    - **Problem Management & Root Cause perform in the Remediation phase**
    - After a return to normal operations, the root cause of the incident should be addressed: what was it that allowed the incident to take place, as an underlying problem
    - Typically, the practice of root cause remediation entails asking “why?” until there are no more valid questions to ask, and the root cause has been determined
    - Once the root cause has been determined, management again needs to be apprised of this information, to decide on how to address the root cause.
    - System administrator restores the system to normal operations and remediates vulnerabilities to prevent similar attacks from occurring again.
- **Root Cause Analysis (RCA)**
    - Asks "WHY" Until there is only one answer
    - An intensive process involving numerous individuals from across disciplines to determine why something happened and how to prevent it in the future.
- Lesson Learned
    - It is extremely useful to the organization that the details of each incident management action be assessed and documented for future use. This is helpful in two ways:
    - It allows the organization to better deal with the same type of incident if it ever happens again.
    - It allows the organization to improve the overall incident management process for use in all future incident management activities.
    - It is just as important to highlight the actions that functioned correctly or achieved successful outcomes as it is to note which aspects of the incident management effort were ineffective and unsuccessful.
- Reporting & Documenting
    - If an incident response team suspects that an incident has occurred, they should start recording information pertaining to the incident.
    - Any and all information specific to the incident in question should be captured and time-stamped.
    - All documents should be dated and signed by the investigators.



- Incident Detection
    - Identify and analyze predictors of compromise (POC) and indicators of compromise (IOC)
        - Examples include IDS, SEIMS, AV, File integrity checking, logs, network flows, threat intelligence, people

- Attack Detection Techniques
  - Problem Management Vs Incident Management
    - Problem Management -- identify the defect, Helps in resolve the problem.
    - Incident Management -- Limited the defect.



- **Operate and maintain detective and preventative measures**
  - Firewall
    - Device that is designed to examine and filter traffic based on a set of rules designed to indicate what will or will not be allowed.
    - Monitors and filters ingress and egress traffic.
    - Network Layer Firewalls
      - Packet Filtering, Stateful firewall
    - Application Layer Firewalls
      - Application-level proxy, Kernel Proxy
      - Application firewall works on layer 7
  - IDS/IPS
    - Monitoring, reporting, and responding to (IPS) intrusion attempts
    - IDS works in Promiscuous mode.
    - **Network Intrusion Detection System (NIDS)**
      - Configure on a Network Level
      - Usually incorporated into the network in a passive architecture - **this means that every packet traversing the network segment is visible.**
      - The System inspects packets and monitors sessions without impacting the system or applications.
      - NIDS Benefits
        - NID less expensive -- not to mention easier to deploy. NIDs also provide a broader examination of a corporate network via scans and probes
    - **Host Intrusion Detection System (HIDS)**
      - Configure on a Host Level
      - Disadvantage:- Cost, it takes a lot of computation
      - implementation of IDS capabilities at the host level, the most significant difference from NIDS is that related processes are limited to the boundaries of a single-host system
      - HIDs Benefits
        - They can prevent attacks from resulting in any damage
  - IDS Analysis Engine Methods
    - Several analysis methods can be employed by an IDS
    - There are two basic IDS analysis Methods:
      - Pattern Matching (Signature Analysis)
        - Pattern matching or signature-based analysis engines behave very similarly to antivirus programs.
      - Anomaly Detection (Behavior Analysis)
        - Profile matching systems look for suspicious activity. These are behavior-based or anomaly-based systems
        - Anomaly (Protocol & Statistical) - disadvantages of a huge amount of False positives
    - Intrusion Detection
      - Pattern/Stateful Machine Engine
        - Pattern Matching Intrusion Detection
          - First IDS product referred to as a signature,
          - Signature is a collection of byte sequence that represents a mode of attack
        - Stateful Machine Intrusion Detection
          - Scan traffic streams rather than individual packets

- Identifies known attacks
- Detects signatures across multiple packets.
- Require periodic update of the signatures.

- Anomaly-Based Engine
  - Statistical / Traffic Anomaly-Based
    - Develop baseline of normal traffic activities and throughput
    - Can identify unknown attacks and DoS
    - Must have a clear understanding of normal traffic
  - Protocol Anomaly Based
    - Can identify unknown attacks
    - May not handle complex protocols (SOAP, XML)
    - Look for deviation standard

- **Signature and Pattern matching**
  - Signature, pattern-matching: patterns from attack scenarios is much like extracting virus signatures from infected, intrusion detection problem as a pattern matching one,
  - **Disadvantage: Signature is not UpToDate we can bypass this.**
  - **Attributes of a pattern matching IDS include:**
    - Identifies known attacks
    - Provides specific information for analysis and response
    - May trigger false-positives
    - Requires frequent updates of signatures
    - Attacks can be modified to avoid detection

- **Protocol anomaly-based (anomaly means Behavior)**
  - Protocol-anomaly-based works by understanding the network protocols (which generally requires having a protocol engine for each network protocol) and by checking or validating the inputs for known abuses.
  - In fact, much of this is really just part of the basic operation of the firewall, creating sessions, matching packets to flows and sessions, and closing sessions
  - **Disadvantage: Lot of False Positive**
    - **Attributes of a protocol anomaly-based IDS include:**
      - Looks for deviations from standards outlined in requests for comment (RFCs).
      - Can identify attacks without a signature.
      - Reduces false-positives with well-understood protocols.
      - May lead to false-positives and false-negatives with poorly understood or complex protocols.
      - Protocol analysis modules take longer to deploy to customers than signatures.

- **Statistical-anomaly based**
  - The Statistical Anomaly Detection method, also known as behavior-based detection, cross-checks the current system operating characteristics on many base-line factors such as CPU utilization, file access patterns, and disk usages.
  - Establish a baseline of normal traffic patterns over time and detect any deviations from that baseline. Some also use heuristics to evaluate the intended behavior of network traffic to determine if it is intended to be malicious or not.
  - Analysis event data by comparing with the known predicted traffic profile.
  - **Attributes of a statistical anomaly-based IDS include:**
    - Develops baselines of normal traffic activity and throughput, and alerts on deviations from these baselines
    - Can identify unknown attacks and DoS floods
    - Can be difficult to tune properly
    - Must have a clear understanding of normal traffic environment

- Intrusion Response
  - Upon detection of an adverse event or suspicious activity, the IDS or IPS can interact with the system, or systems, to restrict or block traffic, and collaborate with other IDS devices of the Logical access control system.
  - There are three fundamental components of an alarm
    - Sensor
    - Control and communication
    - Enunciator (relay system)
- IDS Management
  - One of the most important parts of IDS is the management of the output of IDS, IDS is designed to detect an attack,
  - An effective IDS requires
    - Regular updates
    - Awareness
    - A Technically knowledgeable person

IPS/IDS Tactics

- Whitelisting/Blacklisting
  - Explicit allow or deny an application, protocol, or service control
  - A whitelist is a list of email addresses and/or internet addresses that someone knows as “good” senders. A blacklist is a corresponding list of known “bad” senders.
- Network Access Control (NAC)
  - Governs connections to the network based on configuration requirements (e.g. patch level, AV)
- Data Loss Prevention (DLP)

        - Inspects content to prevent data exfiltration (inadvertent or intended)
    - Sandbox
        - Isolated environment
        - To determine whether a particular component (hardware or software) will operate safely and securely in a particular environment, it is preferable to test it under conditions that simulate that environment but will not affect other components. We often refer to this type of isolated test environment as a **sandbox.**
    - Two general approaches for sandboxing depend on the respective component:
        - **Hardware Sandboxing**: A test environment is created that mimics the production environment such that the test environment contains representative samples of all the devices. The test environment should have no physical connection to the production environment (known as air gapping), and preferably no logical/wireless connection, as well.
        - **Software Sandboxing**: Processes are run in such a way so as not to affect the underlying components (the operating system (OS) or hardware), or other applications running on the same system/environment.
    - Honeypots/Honeynets **(Sudoflaw Keyword)**
        - Decoy systems used to examine attacker activity and techniques
        - Another method for protecting the environment involves the use of **honeypots**: **machines that exist on the network but do not contain sensitive or valuable data**. Honeypots are meant to distract and occupy malicious or unauthorized intruders as a means of delaying their attempts to access production data/assets.
        - Honeypots also provide the organization an opportunity to observe the attack as it is happening to better determine the nature of the attack, possibly identify the attacker, and assess the tools and skill of the attacker, as well as gather evidence for use later in legal action or law enforcement response.
        - Honeypots are placed in the network demilitarized zone (DMZ) and should mimic the architecture of an actual environment.
        - A honeynet is a collection of honeypots
        - A padded cell is a protected honeypot.
    - Anti-Malware
        - Software used to detect and respond to malicious code.
        - The threat of malware is pervasive and persistent, and the means of introducing malware into the environment remain as long as the environment has any contact with the outside world. Therefore, a realistic defense-in-depth strategy should also involve the use of anti-malware solutions.
        - Anti-malware solutions can be installed on network devices and individual systems, as well as mobile endpoints (including user devices, when they are allowed to be connected to the production environment)

- **Implement and support patch and vulnerability management**
    - **Patch Management Program**
        - Create a consistent and configure environment which is secure against known / Unknown Vulnerability, or Zero-Day attack.
        - The main objective of a patch management program is to create a consistently configured environment that is secure against known vulnerabilities in the operating system and application software.
        - An essential part of configuration and change management.
        - **Timing of Patch implementation always incurs a measure of risk as well.**
        - Patch management delays should be evaluated in light of organizational risk tolerance and if applicable, brought to management's attention.
        - Downtime or critical patches we need the RFC.
        - Deploying a Patch **(EXAM IMP)**
            - A Schedule should be established for System deployment
            - User must be notified of system updates prior to deployment.
            - Updates should be scheduled during periods of low productivity.
            - Make certain that a full system backup is conducted prior to deploying updates.
            - Whenever possible an update should be deployed in Stages.
            - Confirm that the updates are deployed to all of the appropriate machines
            - Document the changes
        - Patch Management Process

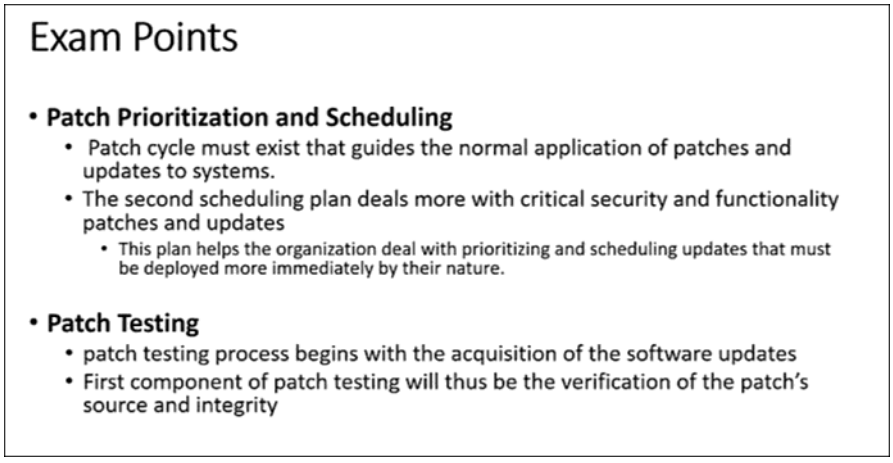


- Patching Challenges
    - **Interoperability:** The organization might apply the patch and then discover that this causes an outage for another system/process within their environment.
    - **Poorly crafted patches:** If a patch is not designed and created properly, the implementation of that patch might degrade system performance, cause the aforementioned interoperability problems, or even introduce new vulnerabilities and risks to the environment.
    - **Required downtime:** Patches often require a reboot of the affected systems to properly take effect; this can interrupt the organization's operations and incur

additional costs

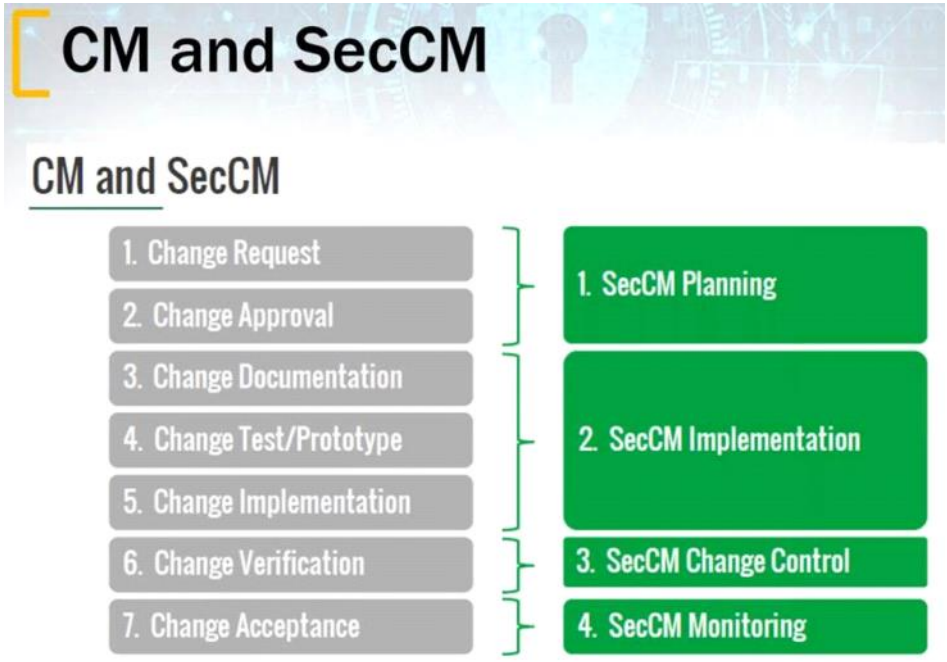
- **Added expense:** the very act of patching entails its own expense: the time of the administrator(s) performing the patch function and the resources necessary to do so properly
- **Virtualization-specific concerns:** Virtualization is the practice of running multiple software-based hosts on a single device; virtualization allows for resource optimization and pooling, rapid scalability, and ease of configuration/replication.
- **Timing:** Because of the aforementioned outage problems/reboot requirements, organizations that operate across multiple time zones are at particular risk of not applying patches uniformly throughout their environment(s).

- **For questions and more clarity refer Patch Management Exam Dose Link**



- Vulnerability management
  - Is the process of identifying, mitigating, and responding to known or anticipated vulnerabilities.
  - Vulnerability management can use automated tools such as vulnerability scanners however, scanners only detect vulnerabilities known at the time of the scan, and for which the scanner has programmed definitions.
  - Scanners do not locate vulnerabilities that have not been identified by the entity which created and updated the scanner (often termed "zero-day" exploits)
  - Vulnerability management can also involve manual testing with users running the software and trying to discover problems.
- Use the following guidelines when implementing patch and vulnerability management:
  - Have a system in place that can perform patch and vulnerability management.
  - Ensure that this management system can determine what systems need to be patched, how to deliver those patches, and when to deliver them.
  - Consider configuring the patch management system to deploy patches to your computers from an internal server, rather than forcing those computers to retrieve patches directly from the Internet or another vendor.
  - If your client machines are on an Active Directory domain, consider pushing out updates to them via Windows Server Update Services (WSUS).
  - When possible, test new patches on non-production systems before deploying them across the organization.
  - Incorporate a testing process into your patch management system

- **Understand and participate in change management processes**
  - Change Management Processes
    - Applies a formal process to accomplish change
    - The change management structure should be included as part of an organization policy.
    - Procedures for the operational aspects of the change management process should be created.
    - Only approved changes will be implemented
    - Periodic reassessment of the environment to evaluate the need for upgrades/Modifications
    - One of the hardest things for many CISSP candidates is avoiding the tendency to FIX the problem.
    - **During an Audit, Change management logs help the auditor, changes in configuration, patch management all are track through change management.**
  - These are the key points of change management:
    - It needs to be a rigorous process that addresses the quality assurance of the change.
    - Changes must be submitted, approved, tested, implemented, and recorded.
    - There should be a back-out plan in case the change is not successful at any point in the change management process
  - Change Management Process Sequence
    - Critical changes are basically first implemented then notify there we raise an RFC for them, Non-Critical changes first we raise RFC, then we update
    - Request
    - Impact Assessment
    - Approval/Disapproval
    - Build and Test
    - Notification
    - Implementation
    - Validation
    - Versioning and Baseline
  - CM & SecCM



- Documentation
  - Be recorded in the appropriate records
  - Include any system modifications that might have been made
  - Include any lessons that were learned during the deployment process
- Security-focused CM
  - The configuration of an Information system and its component has a direct impact on the security posture of the system
  - How those configurations are established and maintained requires a disciplined approach for providing security



- **Implement recovery strategies**
  - Availability
    - Availability is a measure of a system's uptime — the percentage of time that a system is operational and providing its intended service.
    - For example, “five nines” means the device should be up 99.999% of the time and experience no more than 5.26 minutes of downtime per year
  - Resiliency
    - Resiliency is the capability to continue operating even when there has been an attack, disruption, or abnormal operating conditions.
    - Fault tolerance is the capability of a system to continue to operate in the event of failure of one or more system components.
  - Backup Storage Strategies
    - Backup strategies for data used to restore technology are varied and are driven by the Recovery Time Objective (RTO) and the Recovery Point Objective (RPO) needed to support the organizational requirement.
    - Onsite/Offsite
      - Onsite :
        - The organization has full control (and responsibility) of the stored data. Cost may be proportionally higher for the organization, depending on the organization’s core competencies and type of business.
      - Off-Site :
        - The data is exposed to additional risk while it is moved from the organization’s environment to the external environment (in transit). The

organization loses some control of the security governance and controls used to store the data.
    - Cost may be lower or higher than the onsite option, depending on the nature of the organization and the options offered by the provider. A provider with the sole focus on secure data storage may be able to scale services such that secure storage is much more affordable for its clientele.
  - Full/differential/incremental
    - Organizations try to limit the negative impact by scheduling backups in an optimum way to capture the best representation of the current state of the environment with the most acceptable amount of interruption
- **Full**
  - All data in the environment is copied. The most expensive and time-consuming option, and the one that provides the most thorough depiction of the environment.
- **Incremental backup**
  - With incremental backup, only the initial backup is a full one. Subsequent backups only stores changes that were made since the previous backup. The process of restoring lost data from backup is longer but the backup process is much quicker.
  - Backs up all changed files Does reset archive bit
  - Restore Process Full backup + all subsequent incremental
- **Differential Backup**
  - All data in the environment that has changed since the last full backup is copied. Not as time-consuming as a full backup.
  - Differential backup is similar to incremental backup. With both, the initial backup is full and subsequent backups only store changes made to files since the last full backup. This type of backup requires more storage space than incremental backup does, however, but it also allows for a faster restore time.
  - Backs up all files created or modified since the last full backup. Does not reset the archive bit
  - Restore Process Full backup + most recent differential.

Benefits and drawbacks to types of backup

TYPE	BENEFITS	DRAWBACKS
Full	▪ Provides full copy of data set ▪ Offers arguably best protection	▪ Time-consuming ▪ Requires lots of storage space
Incremental	▪ Less time and storage space than full backup	▪ Time-consuming to restore ▪ Need all the backups in backup chain to restore
Differential	▪ Shorter restore time than incremental	▪ Can grow to much bigger size than incremental
Synthetic full	▪ Reduced restore time ▪ Less bandwidth usage	▪ Newer, so not as well-known
Incremental-forever	▪ Availability of data ▪ Automated restoration process	▪ Newer, so not as well-known ▪ Need all the backups in backup chain to restore

- **Any data backup plan must include testing that involves an actual recovery of the data from the backup.**
- **This is the only method for absolutely ensuring that the backup method is operating successfully and that sufficient data is being captured.**
- **Recovery must be performed on a somewhat regular basis (many standards mandate annually) to maintain assurance in the backups**

- Recovery Site Strategies
  - Redundant Center: (MTD /RPO - Zero)
    - This strategy is applied when organizations don't accept downtime. People, Process and Technologies are both the centers. **This is called the Active-Active site**.
    - A mirrored site is fully redundant with real-time replication from the production site.
    - Mirrored site can assume processing with virtually no interruption Expensive, Distance Limitations
    - Advantages of Redundant Center
      - Little or no Downtime
      - Ease of Maintenance
      - No Recovery Required
    - Disadvantages of Redundant Center
      - Most Expensive option
      - Requires redundant hardware, network, staffing.
      - Distance Limitations
  - Internal or External Hot Site
    - **Hot Site is Active - Passive Site**
      There are two types of Hot Sites

      Internal Hot Site - Maintained & managed by the Organization (People, Process and Technology)
      External Hot Site - Maintained & managed by Third-party organization (People, Process, and Technology)

      External Hot site is less expensive than Internal Hot site, whereas Internal Hot site has more control compared to External Hot site. The challenge with the External Hot site is subject to availability during Disaster. Hardware compatibility is another challenge.

- A fully functional operations site that has all necessary hardware, software, and data for instantly handling critical functi ons of the organization
- Hot sites may not have the latest data, and restoration or synchronization of the latest data may be necessary.
- Mirror sites or multiple processing centers have the latest data, and data restoration is usually not necessary.

- Advantages of Internal or External Hot Site
  - Allow recovery to be tested
  - Highly available
  - Site can be operational within Hours
- Disadvantage of the Internet or External Hot Site
  - This high availability comes at a greater cost
  - Hardware and software compatibility issues at external Sites.
- There are two types of Hot Sites
  - Internal Hot Site - Maintained & managed by the Organization (People, Process and Technology)
  - External Hot Site - Maintained & managed by Third-party organization (People, Process, and Technology)
- Warm or Cold Site
  - People Process Technology in warm site but no data, Cold Site in Dump Container (with Power & Water).
  - **Warm:** Similar to a hot site but typically does not have the current version of the organization's data and may not have certain functional aspects ready for instant failover.
  - **Cold:** An empty facility containing no hardware/software/data; utilities may be hooked up but not active. The least expensive option, but it is the one that requires the longest delay between loss of functionality in the primary location and resumption of the critical path.
  - Advantage of Warm and Cold Site
    - Less Expensive
    - Available for longer recoveries
  - Disadvantage of Warm and Cold Site
    - Not immediately available
    - Not fully testable without extensive work.
- Mobile Site
  - A portable facility often mounted on or carried by a vehicle. Can provide operational functionality for a very limited number of users in the critical path but is not limited in placement and location.
  - Advantage of Mobile Sites
    - Highly mobile and relatively easy to transport
    - Modular approach to building data center
    - Building is not required to house equipment.
  - Disadvantage of Mobile Sites
    - Cold Site capability must be built at determined locations
    - The density and design of the container make upgrading and customizing challenging
    - Maintaining a shipping contract or equipment to move the container in time of disaster can be expensive.
- **Reciprocal Agreements:**
  - Reciprocal agreements are between organizations that choose to share the risk of an outage.
  - Each organization is committed to hosting the data and processing of the other in the event of a disaster.
- **Outsourcing:**
  - Eliminates the issues associated with reciprocal agreements and the cost burdens associated with building alternate sites.
  - Especially cost-effective since an organization only incur major costs when a plan is activated.

- Cloud
  - Backup data is stored with a cloud computing service provider; users can resume critical operations from any location with a broadband connection that can reach the cloud provider.
- Updating the kit regularly should be part of the duties of the BCDR team and part of the change management process.
- Backup and Recovery System
  - Backup and recovery system focus on copying data from one location to another so that it can be restored
  - Types
    - Off-site Facility - we have an alternate site that maintained the bunch of data when data not in used
    - Electronic Vaulting - Over the networking, we updating the regular backup.
    - Journaling - Used in database backup, update particular transition in the database.
  - Cloud-Based
    - Cloud Backup Services - Scheduled backup to an Internet location
    - Disk Shadowing - Data is written to (and read from) two or more independent disks Process is transparent to the user
    - Electronic Vaulting - Files copied as they change and periodically transmitted to a backup location
    - Remote Journaling - Transaction logs copied and periodically transmitted to a backup location
    - Automated System Recovery (ASR) - Disk image that can be used to restore operating system files

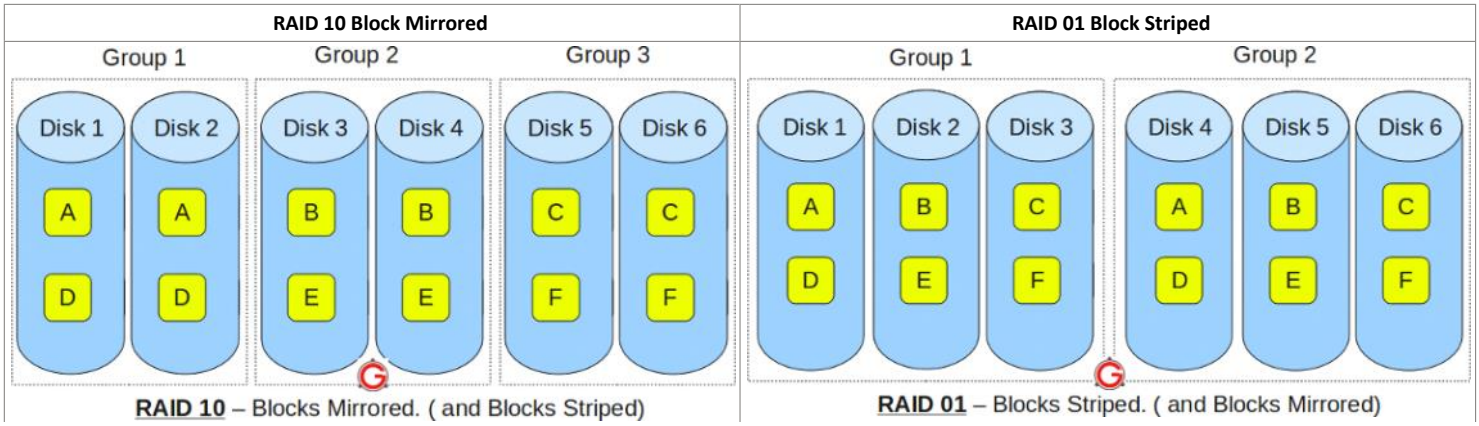
- Reciprocal Agreements
  - Reciprocal agreements are between organizations that choose to share the risk of an outage.
  - Each organization is committed to hosting the data and processing of the other in the event of a disaster.
  - **Live example is Coworking Space.**
  - **Both Sites should belong to the same compliance, Both are vulnerable to the same incident if they are in the same location.**

- Replication Strategy
  - Replication is an automated process that streams copies of data to one or more locations in real-time or near-time.
    - Point-in-Time
      - Periodic snapshots replicated If replicated, snapshots are pointer-based, just changes transmitted
    - Asynchronous Replication
      - Write is considered complete as soon as local storage commits Remote storage updated with a slight time lag

- Synchronous Replication
  - Data written in two locations (local and remote) Both write operations must successfully complete before the system can proceed, Guaranteed zero data loss

- Multiple Processing Sites
  - Some organizations that seek to minimize downtime and enhance BCDR capabilities utilize multiple processing sites to obviate the effects of an impact on any single site.
  - For this technique to function properly, both sites must copy their production data to each other (or at least a sufficient portion of production data to maintain the critical path) on a constant or frequent basis. This requires a communications connection with significant bandwidth and speed. It can also serve as each site's backup archive instead of using a third-party external site.

- System Resilience, High Availability, Quality of Service (QoS), and Fault Tolerance
  - Organizations with extreme sensitivity to downtime—medical providers, military/intelligence agencies, high-volume online retailers, utilities— have a greater need to ensure BCDR capabilities are comprehensive and effective. Here are some techniques for facilitating this practice:
- Outsourcing
  - Eliminates the issues associated with reciprocal agreements and the cost burdens associated with building alternate sites.
  - Especially cost-effective since an organization only incur major costs when a plan is activated.
- Spare Components
  - An organization seeking high availability needs to have sufficient components in inventory to replace/repair any affected elements of the environment (or at least those components supporting the critical path).
  - Redundant items allow a system to continue operating in the events of a component failure
  - Use spare components, leveraging redundant servers or networks and/or redundant data storage.
    - Cold Spares - We have extra storage, Server but not on a Rack
    - Warm Spares - On a Rack but not activate (not Power ON)
    - Hot Spares - On a Rack and its active, waiting for the Primary device to fail
- Clustering
  - Systems can be combined to provide the constant full capacity to the organization when one system/element goes down; this is referred to as "clustering"
  - Two or more systems are joined together to provide service at the same time.
  - Host clustering support. Host clustering provides a way to load balance and make highly available applications. Generally, a cluster solution is one or more servers that work together and can be viewed as a single system.
  - Common modes of clustering include
    - "active-active"- where all systems in the cluster operate in normal production, each handling a portion of the operational load
    - "active-passive" - where at least one of the systems in the cluster doesn't function during normal operations and is only brought online when the normal production system(s) go into a fail state.
- Power
  - interruption of sufficient power can lead to loss of availability just as much as a direct impact on the organization's IT/data.
  - Practical power availability considerations include the following
    - UPS: UPS is only meant to allow users/administrators to conduct formal shutdown procedures on active systems.
    - Generators: Generators should also be paired with a transfer switch, which is a mechanism that detects loss of utility power and engages the generator automatically to compensate.
- Redundant Array Of Independent Disks (RAID)
  - Goal of RAID, improving Read/Write performance of a disk, High availability.
  - An organization can use a RAID (defined as a **"redundant array of independent disks"**) to enhance availability and diminish the risk of downtime due to the failure of a single storage component.
  - A RAID setup entails virtualizing a storage volume across several physical disks so that an entire data set is not lost if a single drive fails.
  - **The technique of writing a data set across multiple drives striping is known as Striping**.
  - **RAID configurations also use a mechanism known as parity bits to allow recovery of the full data set if one drive fails**
  - RAID levels have been standardized to help the system use multiple drives in concert
  - RAID level refers to the way multiple disks can be configured to work together
  - Some RAID levels provide enhanced performance or reliability while others provide both
  - **RAID 10 Blocked Mirrored (and Blocks Striped) is better than RAID 01 Blocks Striped (and Blocks Mirrored)**



- RAID: Redundant array of independent disks. The following RAID levels are important :
  - RAID 0: **stripes data across two or more drives. No parity.** Writes files in stripes across multiple disks without use of parity information. Minimum number of disks required is 2.
    - Benefits/Drawbacks: RAID 0 gives good read/write performance but doesn't provide data redundancy. All data will be lost if one disk fails. RAID 0 should only be used if you can accept data being inaccessible during a drive failure while you restore it from other media.
  - RAID 1: **mirrors data to two or more drives. No parity.** This disk creates identical copies of drives so that redundancy is provided.
    - Benefits/Drawbacks: Having multiple drives with identical data gives high availability in terms of reading performance and boosts data protection. As long as one drive of a mirrored pair doesn't fail, no data is lost. Duplicating drives bring a cost issue into play. Space is effectively utilized since half will be given to another disk and therefore it is very expensive.
  - RAID 3: **byte-level striping with a dedicated parity disk**. Data is striped across multiple disks at a byte level.
    - Benefits/Drawbacks: With a dedicated parity disk rather than interleaved parity stripes, the parity disk can fail and the remaining data will continue to be accessible. The dedicated parity disk is a minor bottleneck as it must be written each time data is updated.
  - RAID 4: **block-level striping with a dedicated parity disk.** Data is striped across multiple disks at the block level.
    - Benefits/Drawbacks: The same as for RAID 3, except random access, is improved with block-level striping.
  - RAID 5: **striping with distributed (interleaved) parity. No dedicated parity disk.** Data and parity Information is striped together across all drives.
    - Benefits/Drawbacks: An array with distributed parity needs all drives but one to be operating. The array doesn't fail if a single disk is destroyed, but will upon a second drive failure. In case of a single disk failure, the array is vulnerable and performance will be reduced until it's replaced and the data rebuilt.
  - RAID 6: **striping with dual distributed parity.**
    Benefits/Drawbacks: Distributed parity gives fault tolerance against two drive failures. Dual parity means that while a failed disk is being rebuilt the array is still protected by the remaining parity data.
  - RAID 0+1: First set of disks stripes all of the data across the available drives and those drives are mirrored to a different set of disks.
  - RAID 1+0: Each drive in the first set of drives is mirrored to a matching drive in the second set.

- **Exam Point**
  - RAID 01
    - It is also called as " Mirror of Stripes"
    - It requires a minimum of 3 disks. But in most cases, this will be implemented as a minimum of 4 disks.
    - **Benefits/Drawbacks:** The array will continue to operate if one or more drives in the same mirror set fail. But if drives on both mirror sets fail, all of the data will be lost. There's a minimum of four disks, and an even number of disks, in a mirrored set.
  - RAID 02
    - It is also called as " Stripe of Mirrors "
    - It requires a minimum of 4 Disks
    - **Benefits/Drawbacks:** If disks fail, RAID 1+0 performs better than RAID 0+1 because all of the remaining disks remain in use. The array can suffer multiple drive failures as long as no mirror set loses all of its drives.
- Staffing for Resilience
  - Avoid single points of failure associated with critical individuals on the operations team.
  - If two or more individuals are capable of providing similar services, then the operation in question will be less influenced by the unavailability of a single individual
  - Adequate staffing levels can also be contingent on when staff will be required.

- **Implement Disaster Recovery (DR) processes**
  - Disaster Recovery
    - Disaster Recovery (DR) means to restore services from a contingency state, DR Typically performs tasks across several areas, including response personnel, communications, assessment, restoration, and training.
    - Disaster Recovery is Recovery Control
    - A disaster recovery /business continuity plan (DR/BCP) should be maintained in a state of readiness, which includes
      - Personnel trained to fulfill their roles and responsibilities within the plan.
      - Plans and strategies exercised to validate their content (including external relationships and communications).
      - Systems and system components tested on a scheduled basis to ensure their recovery and operability.
      - Plan examination and auditing to ensure compliance with business objectives.
  - Documenting the Plan
    - DR Plan must be detailed so a person with skills but without experience executing the procedures, could perform the recovery. The Plan needs to be distributed to everyone who has a role in the case of Disaster Recovery. Recovery site - off-site and command center.
- Plan Should Include :
  - Activation and recovery procedures.
  - Plan Management
  - HR involvement
  - Costs
  - Required Documentation
  - Internal and External Communications.
  - Detailed Action plan per team and team member
- Response
  - A BCDR action can be triggered by a number of possible circumstances (natural disaster/severe weather, fire, physical damage to resources, external attack, etc.); to best manage the activation of the response, the an organization must determine the following:
- Criteria for initiating the response action
  - Criteria might include the dollar value of affected assets, number of affected users, expected duration of system downtime, threat to human health and

safety, and so on

- Personnel authorized to initiate the BCDR Action
  - The person(s) allowed to make this decision for the organization must be trusted and have a significant degree of authority and insight—usually, a member of senior management, if not the head of the organization.
- Once an event is identified, it must be reported to a central communications group responsible for initiating the proper resp onse
- Communications must reach response participants and anyone who is impacted by the event
- Everyone in the organization should have this central number to report problems
- If the events need to be escalated, contact the first escalation team for that event type.
- **Executive Emergency Management Team - Consists of senior management response for recovery**.
  - Handles the strategic issues in case of Disaster
  - Spokesperson of the organization to the media
  - Responds to and helps resolve any issues that need their direction.
  - Decides how the organization manages the business impact of the event.
- Emergency Management Team (EMT)
  - **Tactical (Operational) level** Includes people who directly report to the command center and oversee the recovery and restoration process executed by the emergency response teams.
  - Includes people who directly to the command center and oversee the recovery and restoration process executed by the emergency response teams.
    - Assess preliminary damages
    - Notify senior management of the current status, impact, and plan of action.
    - Declare the disaster if necessary
    - Initiate the plan.
    - Organize and control command centers as a central point of contact
    - Organize and provide administrative support
    - Administer and direct the problem management function.
- Multiple Locations
  - If there are multiple locations for the organization, there needs to be an initial response plan for each site where the organization conducts business

o DR Response Team: Responsibilities
- Retrieve offsite records and recovery information from offsite storage
- Report to the alternate site identified in the procedures
- Execute the recovery process
- Communication the status of the recovery
- Identify issues or problems to be escalated
- Identify issues or problem to be escalated
- Establish shifts for a recovery team
- Restoration or replacement equipment or software

o DRP Teams:
- Rescue: Responsible for dealing with the immediacy of disaster - employee evacuation, “crashing” the server room...etc.
- Recovery: Responsible for getting the alternate facility up and running and restoring the most critical services first
- Salvage: Responsible for the return of operations to the original or permanent facility (reconstitution)

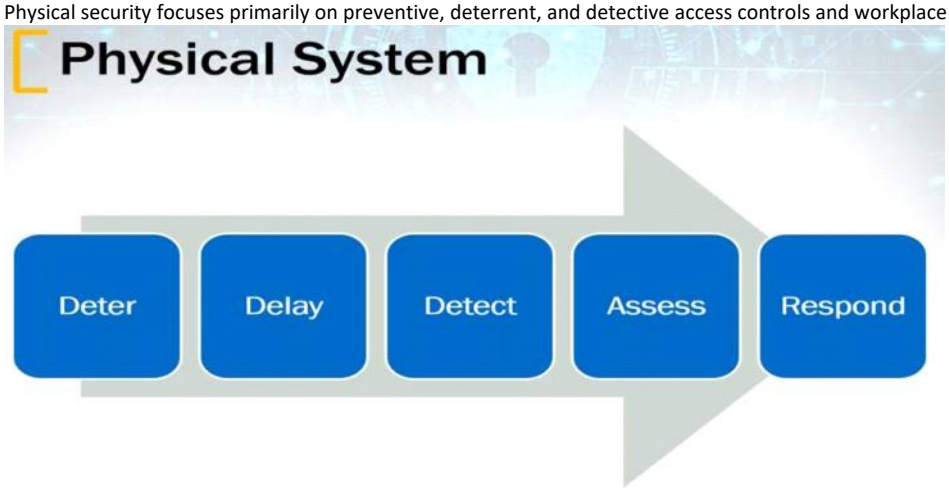
o Maintenance of BCP
- Keeping plan in date
- Make it part of business meetings and decisions
- Centralize responsibility for updates
- Part of the job description
- Personnel evaluations
- Report regularly
- Audits
- As plans get revised, original copies should be retrieved and destroyed

o Personnel
- The member(s) of senior management authorized to initiate the BCDR response action, the response plan should specifically task personnel who will be involved in the process.
- This includes the following:
  - Critical Path Personnel
  - Responders
    - IT, Security, Legal, HR, Finance/accounting
  - Management

- **Test Disaster Recovery Plans (DRP) & Participate in Business Continuity (BC) planning and exercises**
  - o Primary objective of testing the plan is to update the plan.
  - o Testing strategies should include the test scope and objectives test
  - o The objective of a testing program is to ensure that the **business continuity planning process is accurate, relevant, and viable under adverse conditions.**
  - o Testing should happen at least annually.
  - o **Goal of Testing the plan: is to complete the plan, check the effectiveness of the plan & update the plan.**
  - o **Primary Scope - Business and applications identified by BIA, Testing validates the RPO/RTO, the plan intends to restore all the services within the pre-defined MTD.**
  - o Testing Policy
    - Set expectations of a different line of business and support functions to follow
    - The testing cycle should increase in scope complexity over time
    - Should incorporate a risk assessment and a BIA

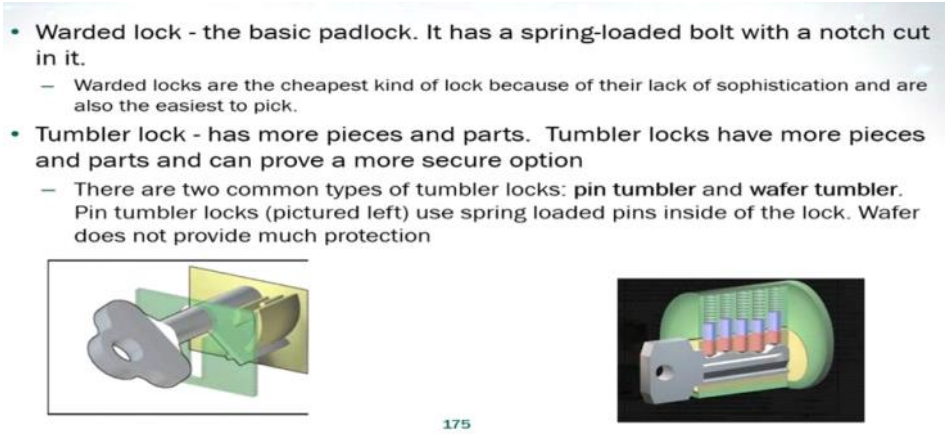
- Testing policies vary in terms of size and risk profile of the organization
- Testing Strategy Types
  - Read-Through Test / Tabletop
    - Personnel or departments review their plans and procedures for accuracy and completeness. All DRP personal read-through the DRP and provide updates and recommendations.
    - Tabletop exercise is excellent for training response personnel unfamiliar with their tasks and/or new to the organization
    - Read-Through tests all each DRP personnel member formally understand their role and responsibilities
    - Read-Through tests differ from checklist tests as DRP personnel review all parts of the DRP, not just their department's inputs.
    - It is excellent for training response personnel unfamiliar with their tasks and/or new to the organization
    - It is the Least Intrusive and Cheapest type of BCDR
    - **Objective - Accuracy, Familiarity, and understand roles and responsibilities**
  - Walk-through Test
    - Scenario-based group workshop focuses on the application of plans and procedures as well as participant readiness
    - **Objective - Coordination, Communication**
    - a walk-through, instead of staying around a conference table, the participants will actually walk to each of the locations they will need to visit for response activities
    - Walk-Through tests also permit real-time updates and improvements based on the different scenario
  - Simulation Test
    - A fire drill where personnel evacuates from the work site is an example of a simulation.
    - Simulations can be much more expensive than a tabletop or walk-through exercises because they involve more people and activity; simulations can also have a greater impact and risk of impact to productivity because work is interrupted for the duration of the test.
    - Simulation tests carry out a disaster scenario under realistic conditions
    - Simulation tests involve DRP personnel conducting a simulated disaster
    - Simulation tests do not typically involve actual relocation to backup facilities.
  - Parallel Test
    - Parallel exercises are for those organizations that utilize alternate operating sites as part of their BCDR plan
    - Parallel tests the DRP at an alternate or backup facility to ensure they can be brought online successfully.
    - Parallel test activates the backup site to ensure it can be brought online with minimal impacts
    - Parallel tests add stress, formal execution steps and give personnel experience executing the DRP
  - Full Interruption
    - Happens once a Year.
    - A full interruption involves the entire organization in a scripted situation that mimics an actual contingency event.
    - All BCDR resources, personnel, and activities are involved and perform the actions they would take during an unscheduled situation.
- Update and maintenance of the plan after testing
  - The plan and all related procedures need to be updated on an on-going basis
  - Procedures should be reviewed periodically
  - Format audit of the procedures annually
  - Version control numbers
- Planning for Disaster Recovery
  - Use the following guidelines when planning for disaster recovery:
    - Follow the disaster recovery planning process.
    - Document the disaster recovery plan based on input from executive-level management.
    - Keep the disaster recovery plan (DRP) was easily accessible by those that need access to it.
    - Consider even the smallest element of business operations to include in the DRP.
    - Consider the risks, cost/benefit analysis, and prioritization required in the disaster recovery process.
    - Qualify potential incidents in the DRP in terms of priority levels.
    - Differentiate various roles and responsibilities for all levels of staff that is affected by the disaster recovery process.
    - Include steps to measure recovery point objective (RPO) and recovery time objective (RTO) in your DRP.
    - Optimize RPO and RTO to be as close to zero as possible.
    - Train all affected staff on their role in the disaster recovery process.
    - Apply different levels of training to different levels of staff.
    - Incorporate regular training exercises into business operations.
    - Assess the DRP to determine its effectiveness and any areas that could use improvement.
    - Define the scope and expectations of your tests.
    - Conduct a test type that is most appropriate and beneficial to the organization without adverting affecting business operations.
    - Use the results of your assessment to improve your DRP and patch up any vulnerabilities.
    - Review the DRP for maintenance every three months.
- Selecting Disaster Recovery Strategies
  - Use the following guidelines when considering disaster recovery strategies:
    - Ensure that you have a data backup strategy that supports your RPO and RTO.
    - Consider where you will store your backups for optimum recovery.
    - Consider what you'll need to back up—source code, application software, configuration files, and anything else that is essential to your business operations.
    - Evaluate which data backup method is most appropriate for your needs. Consider using different methods for different data or systems.
    - Implement redundancy and fault tolerance by using RAID, UPSes, duplicate network links, etc.
    - Choose a RAID solution that strikes a balance between fault tolerance and availability, both compared with your business needs.
    - Consider having a hot, warm, or cold backup site ready in case of a disaster.
    - Understand the major expense involved in maintaining any of these sites—assess if the cost outweighs the value.
    - Consider various recovery site strategies, like having personnel work from home, or contracting with external suppliers.

- **Implement and Manage Physical Security**
  - The primary goal of a physical protection program is to control access into the facility. Essentially, security is comprised of three basic elements.
    - Availability
    - Integrity
    - Confidentiality
  - Key to a successful system is an integration of People, Process and Technologies (Equipment) Layer of Security - Defense in Depth.
  - Physical Security
    - Physical security focuses primarily on preventive, deterrent, and detective access controls and workplace safety



- Deter - Sigs, lights, fences, and guards
- Delay - barbed wire, locks, and guards
- Detect - Access control systems, CCTV, sensors, and monitoring
- Deny - Access control systems, guards, and law
- Physical security is based upon a layered defense model.
  - **Obstacles** to frustrate trivial attackers and delay serious ones.
  - **Detective** controls make it likely that attacks will be noticed.
  - **Response** mechanisms to repel, catch or frustrate attackers.
- Defense in Depth
  - Layered barrier designs are advantageous when they require increased knowledge, skill, and talent to circumvent them
  - Combination People Process and Technology.
- Building Security Controls
  - Access Control
    - Ensures that only authorized personnel is permitted inside the controlled area, Persons subject to control include employees, visitors, customers, vendors, and the general public.
    - Interior Intrusion Detection Systems (IDS): Not all employees need access to sensitive areas, Access control system can provide the necessary security controls.
    - Types of cards
      - Magnetic Stripe (Magstripe) cards
      - Proximity card (Proxy cards)
      - Smart Cards (chip) Two-factor authentication with CC
  - Lighting
    - Lighting for personnel safety and intruder deterrence
    - Intruders are less likely to enter well-lit areas
    - Lighting can be continuous, motion-triggered, random, timed, or standby
    - Lighting should be tamper-proof and have a backup power supply
    - Adequate lighting for monitoring the activities is most important.
  - Signs
    - Signs for personnel safety and intruder deterrence
    - Warning signs indicate surveillance (“You are being watched”)
  - Physical Barrier
    - Fences, walls, gates, barricades, and bollards define the perimeter
    - They serve to prevent, deter, or delay (increase work factor) an attack
    - Turnstiles and mantraps create barriers
    - **Turnstiles** - A turnstile, also called a baffle gate or turn style is a form of gate that allows one person to pass at a time
    - **Mantraps** - A mantrap, airlock, sally port, or access control vestibule is a physical security access control system comprising a small space with two sets of interlocking door
  - Surveillance
    - Closed Circuit TV (CCTV)
      - A Collection of cameras, recorders, switches, keyboards, and monitors that allow viewing and recording of security events (Technical/Detective)
      - Security guard reviewing (Administrative/Detective)
      - Provides a highly flexible method of surveillance and monitoring.
      - Uses of CCTV
        - Surveillance

        - Assessment
        - Deterrence
        - Evidentiary Archives
    - Security personnel
        - Physical presence of guards
- Locks **(IMP EXAM)**
    - Including conventional, pick resistant, cipher, digital, and biometric
    - Combination Locks
        - Lock that requires proper combination pattern to unlock.
        - Used in High Schools
    - Cipher Locks
        - Lock that requires a push-button sequence to unlock
        - Cipher Locks Functionality includes
            - Door Delay - If a door is kept open for a given time, an alarm will trigger.
            - Key Override - Specific combination can be programmed for use in an emergency situation to override normal procedures
            - Master Keying - Supervisory personnel can change access codes and other features
            - Hostage Alarm - Duress alarm combination
    - Smart Locks
        - Allows unique combination to each individual
    - Key lock
        - Key locks require keys to open them. They are easily picked by experts but may include a ward, or obstruction, in the keyhole to prevent uncut keys from opening the locks. Key locks typically use pin tumblers, interchangeable cores, or wafers under springs used for tension. The body and bolt of the lock should be made of substantial materials to withstand bolt cutters and hack saws
    - Deadbolt lock
        - Deadbolt locks are keyed locks that incorporate a bolt into the door frame for added security when used with an alternate type of lock. If the same key is used as the tumbler lock in the door, the protection against lock picking is minimal. Additional protection is gained by making it harder to kick down the door.
    - Duress Alarm
        - Duress is related to the concept of a person doing something or divulging something that they normally would not do under threat of harm. (Panic button)
    - Warded lock & Tumbler Lock
        - **Wafer Tumbler does not provide many protections**
        - **Wafer Tumbler used in a File Cabinet, Pin Tumbler is most commonly used lock.**



- External Monitoring
    - Infrared (IR) Sensors
    - Coaxial Strain-Sensitive cable
    - Lighting
    - Cameras
    - Monitor Displays
    - Guards
    - Alarm
- Guidelines for Implementing Physical Security
    - Use the following guidelines when implementing physical security.
        - Introduce protection in layers (both perimeter and internal) to more successfully delay or stop an attacker.
        - Implement physical access barriers like fences to keep intruders outside of your building perimeter.
        - Choose an appropriate lock type for the physical assets you're trying to protect.
        - Implement physical access controls like man traps to keep attackers out of the building even if they've breached the perimeter.
        - Lock up valuables, sensitive hard copy documents, and physical money in secure storage like a container or safe.
        - Use guards for a human-based control to both perimeter and internal security.
        - Implement a PIDS for comprehensive monitoring of your perimeter.
        - Implement surveillance systems as a component of a PIDS or as part of the building's internal security.
        - Use various types of alarms so that security personnel is alerted to potential attacks.

- **Address Personnel Safety and Security Concerns**
  - Travel
    - Security concerns and risks differ depending on location; the organization should take this into account when personnel are required to work outside the organization's control
    - Some security aspects to consider when personnel is traveling/ working remotely:
      - Encryption: Devices and data that are physically moved to any location outside the organization's control can benefit from the additional protection of encryption; this can protect the organization from loss of data due to interception in transit or physical theft/loss of a device.
      - Secure remote access: personnel are going to connect to the organization's environment from off-site facilities, the organization needs to create a secure mechanism
      - Additional jurisdictional concerns: Data moved across borders may be subject to different statutory/contractual regulation
      - Personnel protection: Personnel need to be protected according to the specific security conditions of geographical areas where they may be traveling
      - Condition monitoring: When personnel is traveling, someone remaining at the organization's primary operating site should be monitoring their location/condition regularly and ensuring daily check-in.
  - Security Training and Awareness
    - Health and human safety is the paramount concern of all security efforts; ensuring personnel are properly trained and aware of safety and security threats and risks are essential
    - This effort should include the following:
      - Location-specific orientation, training, and awareness for travelers (see the previous topic in this module).
      - Emergency procedures (see next topic in this module).
      - Incident reporting procedures (see Module 5 in this domain).
      - Users' role(s) in incident detection and response.
      - How to recognize attack attempts that directly target individual users (phishing, social engineering, etc.).
  - Emergency Safety plans
    - Safety plans including evacuation routes and "safe locations" should be posted and personnel trained
    - Meeting places should be pre-assigned.
    - Evacuation, shelter-in-place, and lock-down drills were practiced.
    - If circumstances allow, personnel should be instructed to secure confidential material and take access control devices with them.
    - No matter what else is happening - human life and safety are always the number one priority.

CBK Notes

- Operations security is primarily concerned with the protection and control of information processing assets in centralized and distributed environments
- Security operations are primarily concerned with the daily tasks required to keep security services operating reliably and efficiently. Operations security is a quality of other services and also a set of services in its own right.
- Live evidence is data that is dynamic and exist in running processes or other volatile locations (e.g., system/device RAM) that disappear in a relatively short time once the system is powered down
- **NIST SP 80086: Computer Forensic Guidelines, SWGDE Best Practices for Computer Forensics,**
- To have effective and efficient incident handling, an organization must possess a solid foundation of knowledge and policy
- When an event becomes an incident, it is essential that a methodical approach be followed. This is necessary given the complexities of dealing with the dynamics of an incident; several tasks must be carried out in parallel as well as serially.
- Triage encompasses the detection, identification, and notification sub-phases. Following the medical model, once an incident has been detected, an incident handler is tasked with the initial screening to determine the seriousness of the incident and to filter out false-positives
  - A good analogy here (and one that is mentioned in several models) is that of a hospital emergency department receiving a new patient. Once the patient arrives, he or she is examined to determine the urgency of care required. Patients with life-threatening conditions receive priority, patients with less life-threatening conditions are placed into a queue, and patients with minor conditions may be directed to their own physicians or neighborhood clinics
- This categorization is used to determine the level of potential risk or criticality of the incident, which in turn is used to determine what notifications are required
- It should be noted that in some cases, complete isolation or containment may not be a viable solution, or if the ultimate goal of the exercise is to track the event or capture additional
- The idea of root cause goes deeper than identifying only symptoms. It looks at what is the initial event in the cause-effect chain
- The security practitioner will need a combination of formal training and sufficient real-world applied experience to make appropriate interpretations without the luxury of an unlimited timeframe.
- Tracking often takes place in parallel with the analysis and examination.
- An important point to consider, as part of developing the incident handling policy and guidelines, is what to do once the root cause has been both identified and traced back to the source
- **Recovery Phase**
  - The goal of this phase is to get the business back up and running (in a worst-case scenario) or, in the best case, bring the affected systems back into production, being sensitive to other activities that may be happening in unison (e.g., tracking and traceback).
  - Once the root cause analysis has provided sufficient information, the recovery process should begin.
  - As was stated earlier, incident response is a dynamic process, with very fuzzy lines between the various phases; often, these phases are conducted in parallel, and each has some natural dependencies on the other. Incident response and handling can be thought of as an iterative process that feeds back into itself until there is some form of closure to the incident
- Any break in this chain can cast doubt on the integrity of the evidence and the professionalism of those directly involved in either the investigation or the collection and handling of the evidence.
- The current protocol for demonstrating authenticity and integrity relies on hash functions that create unique numerical signatures that are sensitive to any bit changes, e.g., SHA-256
- **Interviewing**
  - Witnesses can be easily influenced (often unconsciously), intimidated, or become uncooperative. Therefore, only properly trained and experienced personnel

should conduct a witness interview.
    - All interviews should be conducted under the supervision of legal counsel.
- **Reporting and Documenting**
    - Once an incident has been deemed closed, the incident handling process is not yet complete. One of the most important, yet overlooked, phases is the debriefing and feedback phase
    - The debriefing needs to include all the team members, including representatives from the various business units that may have been affected by the incident.
    - A side benefit to the formalism of the debriefing/feedback is the ability to start collecting meaningful data that can be used to develop or track performance metrics for the response team
- Digital or electronic evidence, although more fragile or volatile, must meet these criteria as well.
- Once evidence associated with a computer crime is lawfully discovered, multiple safeguards should be instituted to preserve its continuity and integrity
- IPS is considered an access control and policy enforcement technology, whereas IDS is considered network monitoring and audit technology
- Egress filtering helps ensure that unauthorized or malicious traffic never leaves the internal network
- It will allow for the ability to attribute certain traffic to endpoints and to individual users, which is important for non-repudiation and data integrity mechanisms
- Data leak prevention (DLP) is a suite of technologies aimed at stemming the loss of sensitive information that occurs in the enterprise
- Least privilege requires that a user or process be given no more access privilege than necessary to perform a job, task, or function. The objective is to limit users and processes to access only resources and tools necessary to perform assigned functions.
    - Ensuring the least privilege requires identifying what the user's job is, determining the minimum set of privileges required to perform that job, and restricting the user to a domain with those privileges and nothing more.
- If the goal of least privilege is reducing access to a bare minimum, the need to know defines that minimum as a need for access based on job or business requirements.
- Efficient management of users requires the assignment of individual accounts into groups or roles
- Privileged entities possess extensive powers on a given system. While these privileges may be necessary, they could be misused by unscrupulous individuals or targeted by external attackers.
    - These accounts should be renamed whenever possible and strictly controlled. Default passwords should be changed prior to adding the device or computer to the production network
- It is also important that all actions taken by an administrative account are audited
- Security administrators are responsible for defining the security settings of a system.
- Help/Service desk personnel are responsible for providing front line support for all users
- A security professional is expected to ensure accounts and their privileges are assigned appropriately and reviewed on a regular basis
- Job Rotation Job rotations reduce the risk of collision of activities between individuals
- information owner must work with the information security program and officer to ensure the protection, availability, and destruction requirements can be met.
- Categorization is the process of determining the impact of the loss of confidentiality, integrity, or availability of information to an organization
- Classification and categorization are used to help standardize the defense baselines for information systems and the level of suitability and trust an employee may need to access information
- SLAs are between companies and external suppliers, but they may also be between two departments within a company
- The SLA should include components in two areas: services and management
    - Indemnification means that the provider will have to pay the customer for any third-party litigation costs resulting from its breach of the warranties
- Backups contain information that is regularly processed by the system users. Information that is needed for historical purposes, but not in continual use, should be saved and removed from the system as an archive
- A successful incident management program combines people, processes, and technology
- Incident management procedures are intended to guide all activities related to the incident and guide the security practitioner down a pre-defined and (where possible) pre-approved path for resolution.
- Technical reporting tends to be designed for technical specialists or managers with direct responsibility for service delivery. Management reporting will provide summaries of multiple systems as well as key metrics for each of the services covered by the report.
- Boundary controls may be placed wherever there is a necessary division between more trusted and less trusted environments
- Security operations will focus on ensuring that these technologies have been deployed effectively and monitoring their use overtime to ensure that they are still effective.
- Intrusion detection and prevention systems are used to identify and respond to suspected security-related events in real-time or near real-time
- **False-positives** occur when the IDS or IPS identifies something as an attack, but it is normal traffic. **False-negatives** occur when the IPS or IDS fails to interpret something as an attack when it should have
- Anti-Malware Systems
    - To remain effective, anti-malware solutions require continual updates and must be monitored to ensure they are still active and effective
- Recovery
    - The first step of recovery is eradication if possible. Eradication is the process of removing the threat.
- Remediation and Review (Lessons Learned)
    - Organizations have an opportunity to analyze and understand what failed and try to ensure it does not happen again
- Root Cause Analysis
    - RCA involves reviewing system logs, policies, procedures, security documentation, and network traffic capture if available to the first piece together the history of the event that caused the incident.
- While incident management is concerned primarily with managing an adverse event, problem management is concerned with tracking that event back to a root cause and addressing the underlying problem.
    - While incident management is focused on limiting the effect of an incident, problem management is about addressing defects that made the incident possible or more successful.
- A security review is conducted by the system maintenance or security personnel to discover vulnerabilities within the system. A vulnerability occurs when policies are not followed, misconfigurations are present, or flaws exist in the hardware or software of the system.
- Penetration testing is a form of security review where an attempt is made to gain access or compromise a system
- Security audits can be divided between internal and external reviews
    - Entities performing an external review provide an independent assessment of the system.
- The outcome of the security audit and review process should be a list of items and issues that have to be addressed by the security actors in the organization

- NIDS can also fail to provide adequate monitoring if the traffic it is monitoring is encrypted
- HIDS is the implementation of IDS capabilities at the host level
- HIDS can consume inordinate amounts of CPU and memory to function effectively
- If a new or different attack vector is used, it will not match a known signature and, thus, slip past the IDS
- An IDS is designed to alert an administrator in the event something is detected
- IDS is designed to detect and, if possible, identify an attack
- Sandboxing is a form of software virtualization that lets programs and processes run in their own isolated virtual environmen t
- Sandboxing, one alternative to traditional signature-based malware defense, is seen as a way to spot zero-day malware and stealthy attacks in particular.
- AMTSO's charter focuses on the following four areas:
    - 1. Providing a forum for discussions related to the testing of anti-malware and related products.
    - 2. Developing and publicizing objective standards and best practices for testing anti-malware and related products.
    - 3. Promoting education and awareness of issues related to the testing of anti-malware and related products.
    - 4. Providing tools and resources to aid standards-based testing methodologies.
- The main objective of a patch management program is to create a consistently configured environment that is secure against kn own vulnerabilities in operating systems and application software
    - Prior to deploying updates to production servers, make certain that a full system backup is conducted
    - After the deployment, it is necessary to confirm that the updates are deployed to all of the appropriate machines.
    - The last step in the patch management process is to document the changes.
- Change management is vital to every stage of the patch management process
- Regular audit and assessments help gauge the success and extent of patch management efforts.
- Audit and assessment efforts can be considered "after the fact" evaluation of compliance because the systems being evaluated will typically be already deployed into production.
- Maintaining system integrity is accomplished through the process of change control management
- **The change management structure should be codified as an organization policy.**
- **Change management policies and procedures are forms of directive controls**
- Configuration management is a process of identifying and documenting hardware components, software, and the associated settin gs
    - The inventory is also helpful for integrity purposes when attempting to validate systems, software, and devices on the network.
    - Software configurations and their changes should be documented and tracked with the assistance of the security practitioner
- If the backup tapes are stored somewhere else besides an alternate site, then the time it takes to pack and transport those t apes must be included in the RTO
- If a company wants the backup and recovery strategy to be as simple as possible, then they should only use full backups
- An incremental backup takes the most time in restoration because the full backup must be performed first and then every incre mental backup was taken since the last full backup
- The RTO or Maximum Tolerable Downtime (MTD) for a business process or an application is going to determine the recovery strat egy for the process or application
- In clustering, two or more members are joined into the cluster and may all provide service at the same time
- An important part of maintaining resilient operations is ensuring adequate and trained staff is available to keep everything running smoothly.
- Disaster recovery is the process of restoring services from a contingency state.
- Disaster Recovery Plan
    - Conducting exercises is also a form of training for those who have a direct role in the recovery. Whether the exercise is a tabletop exercise, an actual exercise at the alternate site, or just a call notification exercise, the team will practice their role during the exercises. The more the plan is exercised, the more confident the recovery team will be if or when it happens for re
- The BIA determines the recovery point objectives and recovery time objectives, which then help determine the appropriate reco very strategy. Validation of the RPOs and RTOs is important to ensure that they are attainable
- It is often wise to stop using the word "test" for this and begin to use the word exercise. The reason to call them exercises is that when the word "test" is used, people think pass or fail. There is no way to fail a contingency test. If the security professionals knew that it all worked, they would not bother to test it. The reason to test is to find out what does not work so it can be fixed before it happens for real.
- Testing methods include both business recovery and disaster recovery exercises. Business recovery exercises primarily focus o n testing business line operations, while disaster recovery exercises focus on testing the continuity of technology components, including systems, networks, appl ications, and data
- The senior manager of each operating area has the responsibility for ensuring the organization's survival.
- The business continuity planners act as a focal point for their company in any situation involving contingency planning or em ergency response
- The defense-in-depth principle may seem contradictory to the "secure the weakest link" principle because we are essentially saying that defe nses taken as a whole can be stronger than the weakest Link
- The most commonly used fence is the chain-linked fence, and it is the most affordable. The standard is a six-foot-high fence with two-inch mesh square openings. The material should consist of nine-gauge vinyl or galvanized metal. Nine-gauge is a typical fence material installed in residential areas.
- Wall
    - To be most effective, walls ought to be 7 feet high with 3 to 4 strands of barbed wire on top. This will help deter scaling
- Closed-circuit television (CCTV) is a collection of cameras, recorders, switches, keyboards, and monitors that allow viewing and rec ording of security events
- proprietary security operations have their disadvantages, including cost, administration, staffing, impartiality, and experti se
    - A considerable disadvantage of a proprietary service is the time it would take a firm to establish its own program, from selecting ahead of security, filling of numerous positions, and the specific training that would be needed
- Perimeter doors should consist of hollow steel doors or steel-clad doors with steel frames. Ensure the strength of the latch and frame anchor equals that of the door and frame.
- If perimeter doors are made of glass, make sure that the material is constructed of a laminate material or stronger. Ensure t hat glass doors only allow access into a public or lobby area of the facility
- Locks
    - Wafer tumbler lock– file cabinet locks - uses wafers instead of pins and is fairly easy to beat
    - Pin tumbler lock– door lock - the key raises individual pins, allowing the cylinder to rotate
    - Lever tumbler lock– safe locks - use moving levers to unlock
- Cylinder locks come in 3 levels of security in terms of their resistance to lock picking (opening a lock without the required key):

    - Low security– no resistance
    - Medium security– some resistance
    - High security–resistance provided through multiple mechanisms (Grade 1 or Grade 2 locks only)
- Duress situations are extremely challenging with sometimes deadly or life-altering consequences. It is used for immediate
- When an employee has been subject to duress, the organization should provide sufficient and specific support to the employee and allow them time to recover.